Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.11 / COMPANION WORKBOOK

Stand up the business services

Files, database, licensing & web — by documented paths

Give the users what the network exists for: SBD-FS01's role-based shares over verified SMB security, SBD-SQL01 running as a managed identity behind exactly two callers, SBD-APPS01's licensing service, and SBD-WEB01 serving internal HTTPS from a hardened Apache — every hop a documented, proven register row.

MATERIALS EDITION 1.0 / COURSE 1.11

Updated 7 October 2026 · sbd-business-services

NAME _____ / DATE _____

© 2026 Secure By Design Team LLC.

START HERE / YOUR LEARNING PATH

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Design the service paths and identities

02 Build SBD-FS01 with least-privilege shares

03 Build SBD-SQL01 behind its applications

04 Build SBD-APPS01 and SBD-WEB01

05 Reconcile, scan, and close the wave

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

Before you start

The users finally get what the network exists for: files, a database, licensing, and an internal web service. The model's rule governs the whole wave — permit only documented business service paths — so every service arrives with its register rows, its service identity, and its certificate, and nothing reaches it any other way.

Prerequisites

- ☐ Complete courses 1.5–1.10: the routed, watched, managed network with working PKI services and the ring/source rules in force.
- ☐ Provision the VLAN 40 hosts: SBD-FS01 (10.0.40.10), SBD-SQL01 (10.0.40.20), SBD-APPS01 (10.0.40.30), and SBD-WEB01 (10.0.40.40, Linux with Apache).
- ☐ Have the course 1.5 register and the course 1.6 SBD Server Authentication template ready — every service here gets a documented path and a real certificate.

What this course builds

- Serve files through role-group permissions with verified SMB signing and encryption.
- Run the database as a managed identity, certificate-encrypted, behind its two applications.
- Prove the fleet → web → database chain with every hop registered and every shortcut denied.

Systems in scope

RECORD	YOUR OBSERVATION
SBD-FS01 — name, address, OS build	
SBD-SQL01 — name, address, OS build	
SBD-APPS01 — name, address, OS build	
SBD-WEB01 — name, address, OS build	

© 2026 Secure By Design Team LLC.

LESSON 01 / ABOUT 25 MIN

Design the service paths and identities

WHY THIS MATTERS Four services, and before any of them exist: who talks to what over which port, which identity each service runs as, and which groups own access — the register and the directory answer all three before a role installs.

In this lesson you will

- Write the register rows for every business service path.
- Choose managed service identities instead of password accounts.
- Define the access groups that will own each service's data.

Follow the build

1. Write the service-path rows: fleet to FS01 (SMB 445), fleet to APPS01 (its licensing port) and WEB01 (HTTPS 443), WEB01 and APPS01 — and only they — to SQL01 (1433). Everything else toward VLAN 40 stays denied, including endpoint-to-SQL directly.
2. Choose the service identities: group managed service accounts for the SQL and application services, so passwords rotate themselves — and note Windows Server 2025's delegated managed service accounts as the migration path for any legacy service account this lab later inherits.
3. Create the access groups under the course 1.3 Groups OU — per-share and per-application role groups — because permissions will be granted to roles, never to named humans.
4. Request the server certificates through the course 1.6 process: one SBD Server Authentication certificate each for SQL01 and WEB01, enrolled from the template, with the publication site serving their revocation story.

Check your result

```
Get-ADServiceAccount -Filter * | Select-Object Name, Enabled
Get-ADGroup -SearchBase 'OU=Groups,OU=SBD,DC=sbd,DC=test' -Filter * | Select-Object Name
Test-NetConnection 10.0.40.20 -Port 1433   # expected before build: TcpTestSucceeded False
```

WHAT SUCCESS LOOKS LIKE The register carries the four services' rows with the SQL path restricted to its two callers, the gMSAs and role groups exist, and both server certificates are issued and recorded.

Your record

Evidence to keep: Keep the service-path rows, the identity and group design, and the certificate enrollment records.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

Who may reach SQL01 on 1433?

REMEMBER Every path is a row; the database hears only its applications. Service identities are managed accounts, not passwords. Access belongs to roles; certificates are already in hand.

Microsoft · Group managed service accounts

Microsoft · What's new in Windows Server 2025

NIST · SP 800-53 Rev. 5 security controls

LESSON 02 / ABOUT 30 MIN

Build SBD-FS01 with least-privilege shares

> **WHY THIS MATTERS** The file server is where access control meets daily life. Build the shares against the role groups, lean on the SMB security the platform now enforces, and make 'who can read this' a one-lookup question.

In this lesson you will

- Create the shares with role-group permissions and no individual grants.
- Confirm the SMB signing and encryption posture end to end.
- Verify access and denial per role from the fleet.

Follow the build

1. Build SBD-FS01 in the Servers OU and create the planned shares, granting NTFS permissions to the lesson-1 role groups only — share permissions stay simple, the filesystem carries the detail, and no named human appears in an ACL.
2. Enable access-based enumeration so users see only what their roles permit — the quiet UX of least privilege.
3. Confirm the SMB posture: Windows Server 2025 and the Windows 11 fleet already require signing by default, and this share design opts into SMB encryption for the sensitive share — verify both on a live session rather than assuming the default.
4. Test as members of two different roles from fleet machines: each sees and opens exactly its shares, the other's are invisible and denied, and the denial lands in the pipeline like every other refusal on this network.

Check your result

```
Get-SmbShare | Select-Object Name, Path, FolderEnumerationMode
Get-SmbSession | Select-Object ClientComputerName, Signed, Encrypted   # run during the test session, on FS01
icacls D:\Shares\Projects | Select-String 'SBD'
```

> **WHAT SUCCESS LOOKS LIKE** Shares grant to role groups only, a live session shows signing (and encryption where designed), and the two-role test proves both the access and the invisible-denied behavior.

Your record

Evidence to keep: Keep the share and NTFS permission reports, the live session's signing/encryption output, and the two-role test record with its pipeline entry.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	

RECORD	YOUR OBSERVATION
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Where does the fine-grained permission detail live?

> **REMEMBER** Roles own the ACLs; humans own role memberships. Signing and encryption are verified on a live session. Both the access and the denial are on record.

Microsoft · SMB security enhancements

Microsoft · What's new in Windows Server 2025

LESSON 03 / ABOUT 30 MIN

Build SBD-SQL01 behind its applications

WHY THIS MATTERS The database runs as a managed identity, encrypts its connections with a real certificate, and answers exactly two callers — the narrowest audience on the network, by design.

In this lesson you will

- Install the database service under its gMSA.
- Bind the SBD Server Authentication certificate for encrypted connections.
- Prove the two-caller rule: applications connect, everything else is refused.

Follow the build

1. Install the database engine on SBD-SQL01 with the lesson-1 gMSA as its service identity — the install itself demonstrates the managed account working where a password account used to live.
2. Bind the issued certificate to the instance and require encrypted connections; the chain validates against pki.sbd.test like every other certificate on this network.
3. Create the application databases with role-based database access for the WEB01 and APPS01 identities — least privilege continues inside the engine, not just at its port.
4. Prove the audience: a connection from WEB01 succeeds encrypted; the same attempt from a fleet machine dies at the boundary with a deny-log entry — the register row, demonstrated from both sides.

Check your result

```
Get-Service MSSQLSERVER -ComputerName SBD-SQL01 | Select-Object Status
# From SBD-WEB01: the registered caller connects. From a fleet machine:
Test-NetConnection SBD-SQL01.sbd.test -Port 1433   # expected from fleet: TcpTestSucceeded
False
certutil -verify -urlfetch C:\Evidence\services\sql01.cer
```

WHAT SUCCESS LOOKS LIKE The service runs as the gMSA, connections are certificate-encrypted with a validating chain, application access works by database role, and the fleet's direct attempt fails with its logged deny.

Your record

Evidence to keep: Keep the service identity proof, the certificate binding and urlfetch output, the database role grants, and the paired success/deny connection evidence.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

What demonstrates the gMSA actually working?

> **REMEMBER** A managed identity runs the engine; no password exists to leak. Connections encrypt under the lab's own validated chain. Two callers in, everyone else logged out at the boundary.

Microsoft · Securing SQL Server

Microsoft · Group managed service accounts

LESSON 04 / ABOUT 35 MIN

Build SBD-APPS01 and SBD-WEB01

> **WHY THIS MATTERS** The licensing service and the internal web server complete the dependency chain: fleet to application, application to database — each hop registered, the web tier hardened against its DISA guidance, and HTTPS served from the lab's own trust.

In this lesson you will

- Stand up the licensing service with its registered fleet path.
- Build the Apache server hardened per its STIG guidance, serving HTTPS with the internal certificate.
- Prove the full chain: fleet → web → database.

Follow the build

1. Build SBD-APPS01 in the Servers OU, run its licensing service under a managed identity, and verify the fleet path on the registered port — the smallest of the four services, and the template for any future one: identity, row, evidence.
2. Build SBD-WEB01 on the Linux platform, packages from SBD-REPO01 only, and harden the web tier against DISA's Apache guidance — the server's assessable record follows the Linux pattern: hardened configuration exported and hashed, checklist items answered in STIG Viewer.
3. Install the SBD Server Authentication certificate with its chain and serve the internal application over HTTPS — the 2,048-bit floor from the accuracy review applies here as everywhere.
4. Prove the chain from a fleet machine: the HTTPS page loads with a validating certificate, the page's data round-trips through SQL01, and the fleet still cannot touch 1433 directly — three courses of design visible in one browser request.

Check your result

```
Test-NetConnection SBD-WEB01.sbd.test -Port 443
# From a fleet machine, trust and chain:
certutil -verify -urlfetch C:\Evidence\services\web01.cer
Test-NetConnection SBD-SQL01.sbd.test -Port 1433   # from fleet, still expected: False
```

> **WHAT SUCCESS LOOKS LIKE** The licensing path works as registered, the Apache host serves HTTPS with a validating internal chain from a hardened, hashed configuration, and the end-to-end request proves fleet → web → database with the shortcut still denied.

Your record

Evidence to keep: Keep APPS01's identity and path proof, WEB01's hardened config export with hashes and checklist, the certificate validation output, and the end-to-end chain test.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Where do WEB01's packages come from?

REMEMBER Two services, two identities, every hop a register row. The web tier is hardened to its guidance and serves the lab's own trust. One page load proves the dependency chain end to end.

Microsoft · Securing SQL Server

DISA · STIGs and GPO package (incl. Apache guidance)

NIST · SP 800-53 Rev. 5 security controls

LESSON 05 / ABOUT 30 MIN

Reconcile, scan, and close the wave

WHY THIS MATTERS The service wave closes the way every wave has: the register reconciled against live behavior, the new systems baselined, the inventory updated — and for the first time, the network is functionally complete.

In this lesson you will

- Reconcile the full register against observed permits and denies.
- Baseline the four service hosts and rescan what changed.
- Update the living records and write the wave's handoff.

Follow the build

1. Run the full-register reconciliation one more time: every business-service row proven from its real source, every adjacent deny probed and logged — the VLAN 40 section of the matrix joins the evidence beside courses 1.5 and 1.7's.
2. Run the cadence: SCAP baselines for FS01, SQL01, and APPS01; the config-export record for WEB01; a credentialed scan of VLAN 40 from SBD-NESSUS01 with its findings triaged into the three classifications.
3. Update the living records: the four hosts, their identities, certificates, and rings into the SBD-MGMT01 inventory; the new rows' owners into the register; any service-hardening deviations into the exception record.
4. Write the handoff: every modeled system except the recovery design is now built, watched, patched, and evidenced — course 1.12 proves the network can come back from the dead, and then path 2 takes the whole record to authorization.

Check your result

```
Get-ChildItem C:\Evidence\business-services -Recurse | Select-Object Name, LastWriteTime
Get-FileHash -Algorithm SHA256 C:\Evidence\business-services\*
```

WHAT SUCCESS LOOKS LIKE The matrix covers every VLAN 40 row with paired permit/deny proof, the four hosts carry baselines or config records with triaged scan findings, and inventory, register, and exception record all reflect the finished wave.

Your record

Evidence to keep: Finish the checklist: the reconciliation matrix, the scan and triage set, the updated living records, and the handoff note to course 1.12.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why re-run the whole register reconciliation now?

REMEMBER Register and reality reconcile across the finished network. Every service host carries its platform-appropriate evidence. One course remains: proving the network can be brought back.

DISA · STIGs and GPO package (incl. Apache guidance)

NIST · SP 800-53 Rev. 5 security controls

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Design the service paths and identities	☐ yes	
02 Build SBD-FS01 with least-privilege shares	☐ yes	
03 Build SBD-SQL01 behind its applications	☐ yes	
04 Build SBD-APPS01 and SBD-WEB01	☐ yes	
05 Reconcile, scan, and close the wave	☐ yes	

Open items carried forward

Next in the learning path

That completes course 1.11. Course 1.12 closes the Build path by proving recovery — directory, CA, policy, and logs — before authorization begins.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.